

POLÍTICA DE SEGURIDAD DLP: CONTROL DE DISPOSITIVOS DE ALMACENAMIENTO EXTERNO

1. Introducción al Data Loss Prevention (DLP)

La Prevención de Pérdida de Datos (Data Loss Prevention, DLP) es el conjunto de políticas, procesos y tecnologías diseñadas para detectar y evitar que información confidencial salga del control de la organización, ya sea de forma accidental o intencionada. Dentro de la organización, el DLP cumple un papel central para proteger datos de clientes, propiedad intelectual e información financiera frente a fugas de información.

Los dispositivos de almacenamiento externo (memorias USB, discos duros portátiles, tarjetas SD, entre otros) representan uno de los vectores de fuga de datos más comunes y difíciles de controlar, ya que permiten copiar grandes volúmenes de información fuera de la red corporativa en segundos, sin dejar rastro si no existen controles técnicos adecuados. Además, estos dispositivos pueden introducir malware en la red (por ejemplo, ataques tipo BadUSB) o perderse físicamente, exponiendo su contenido a terceros no autorizados.

Esta política establece las reglas y controles necesarios para que el uso de dispositivos de almacenamiento externo en la organización sea seguro, trazable y coherente con el Principio del Menor Privilegio.

2. Clasificación de Datos

Para determinar qué información puede o no salir de la organización a través de dispositivos externos, la organización clasifica sus datos en tres categorías:

Categoría	Descripción	Permiso en Dispositivos de Almacenamiento Externo
Datos Públicos	Información general de la empresa sin impacto si se divulga (folletos, comunicados, material de marketing).	Permitido sin restricciones especiales.
Datos Internos	Información de uso interno no destinada al público (procedimientos, documentación de proyectos internos, comunicaciones internas).	Permitido solo en dispositivos cifrados y previamente autorizados por TI.
Datos Sensibles	Información altamente confidencial: datos financieros, contratos, propiedad intelectual, datos personales de clientes o empleados.	Prohibido por defecto. Excepción únicamente con autorización formal, cifrado obligatorio y trazabilidad completa.

Esta clasificación debe estar reflejada mediante etiquetas visibles o metadatos en los documentos y sistemas, de forma que tanto los empleados como las herramientas de DLP puedan identificar automáticamente el nivel de sensibilidad de cada archivo antes de permitir su copia a un dispositivo externo.

3. Acceso y Control (Principio del Menor Privilegio)

El acceso a los puertos USB y demás interfaces de almacenamiento externo se gestiona bajo el Principio del Menor Privilegio, de la siguiente manera:

- **Bloqueo por defecto:** Por defecto, todos los puertos USB y unidades de almacenamiento externo estarán bloqueados a nivel de sistema operativo en los equipos corporativos, mediante políticas de grupo (GPO) o herramientas de gestión de dispositivos móviles/endpoints (MDM/EDR).
- **Acceso basado en necesidad:** El acceso solo se habilita para roles cuya función lo requiera de forma justificada (por ejemplo, personal de soporte técnico que necesite transferir imágenes de sistema), y siempre limitado a dispositivos incluidos en una lista blanca gestionada por TI.
- **Solicitud y aprobación formal:** Cualquier solicitud de acceso temporal a almacenamiento externo debe ser aprobada formalmente por el responsable directo del empleado y por el Departamento de Seguridad de la Información, indicando el motivo, la duración y el alcance del acceso.
- **Expiración automática:** El acceso concedido se revoca automáticamente al finalizar el plazo autorizado o el proyecto que lo motivó, sin requerir una acción manual adicional.
- **Revisión periódica:** Los permisos de acceso a dispositivos externos, junto con la lista de dispositivos aprobados, serán revisados trimestralmente para asegurar que solo el personal activo y con una necesidad vigente conserve el acceso.

La siguiente tabla resume los roles responsables de este proceso:

Rol	Responsabilidad en el control de dispositivos externos
Departamento de Seguridad de la Información	Define la política, aprueba o rechaza solicitudes de excepción, revisa alertas del sistema DLP y coordina auditorías trimestrales.
Equipo de TI / Infraestructura	Configura el bloqueo por defecto de puertos USB a nivel de endpoint, gestiona la lista blanca de dispositivos aprobados y aplica el cifrado obligatorio.
Responsables de Departamento (Managers)	Solicitan formalmente el acceso temporal para su equipo cuando sea necesario y validan que la necesidad de negocio sea real.
Empleados	Utilizan únicamente dispositivos autorizados, reportan de inmediato la pérdida de un dispositivo y cumplen las políticas de clasificación de datos.

4. Monitoreo y Auditoría

Para garantizar que la política se cumpla en la práctica, se implementarán las siguientes herramientas y reglas de monitoreo:

- **Solución de DLP en endpoints:** Se desplegará una solución de DLP en los endpoints (por ejemplo, Microsoft Purview Endpoint DLP, Symantec DLP o una alternativa equivalente) capaz de detectar e inspeccionar el contenido que se intenta copiar a un dispositivo externo, bloqueando automáticamente las transferencias que contengan datos clasificados como Sensibles.
- **Integración con SIEM:** Todos los eventos relacionados con dispositivos externos (conexión, desconexión, lectura, escritura, intentos bloqueados) se integrarán a una plataforma SIEM (por ejemplo, Splunk o Microsoft Sentinel) para su correlación con otros eventos de seguridad de la red.

- **Alertas automáticas:** Se configurarán alertas en tiempo real hacia el equipo de Seguridad cuando se detecte un intento de transferencia de datos sensibles, la conexión de un dispositivo no autorizado, o un volumen de copia inusualmente alto.
- **Auditorías trimestrales:** El Departamento de Seguridad realizará auditorías trimestrales sobre los registros de uso de almacenamiento externo, verificando el cumplimiento de la política y documentando cualquier hallazgo o incidente.

5. Prevención de Filtraciones

Además de los controles de acceso, se aplicarán las siguientes medidas técnicas para reducir el riesgo de filtración de datos a través de dispositivos externos:

- **Cifrado obligatorio:** Todo dispositivo de almacenamiento externo aprobado deberá contar con cifrado de disco completo (por ejemplo, BitLocker To Go o FileVault) antes de poder ser utilizado con información corporativa.
- **Inspección de contenido:** El sistema de DLP inspeccionará el contenido en tiempo real (no solo el tipo de archivo) para detectar patrones de datos sensibles —como números de tarjeta, identificadores personales o cláusulas contractuales— y bloquear su copia aunque el dispositivo esté autorizado.
- **Bloqueo de autorun:** Se deshabilitará la función de autoejecución (autorun) en todos los equipos corporativos para reducir el riesgo de propagación de malware a través de dispositivos externos.
- **Permisos de solo lectura por defecto:** Para la mayoría del personal, el acceso concedido a dispositivos externos será de solo lectura; los permisos de escritura/copia se reservarán a los responsables directos que justifiquen dicha necesidad.
- **Inventario y etiquetado físico:** Todo dispositivo aprobado se registrará en un inventario con número de serie, responsable asignado y fecha de aprobación, permitiendo rastrear su uso y asegurar su devolución o baja al finalizar su uso.

6. Educación y Concientización

El cumplimiento efectivo de esta política depende en gran medida de que el personal comprenda los riesgos asociados al uso de dispositivos de almacenamiento externo. Para ello, la organización implementará:

- **Capacitaciones trimestrales:** Sesiones obligatorias cada trimestre sobre el uso seguro de dispositivos externos, el proceso de solicitud de acceso y las consecuencias de incumplir la política.
- **Casos y simulacros:** Durante las capacitaciones se presentarán casos reales de incidentes relacionados con USB (dispositivos perdidos con información sensible, ataques BadUSB, filtraciones accidentales) y las señales de alerta que el personal debe reconocer.
- **Canal de reporte:** Se establecerá un canal claro y de fácil acceso (correo o formulario interno) para que cualquier empleado reporte de inmediato la pérdida de un dispositivo autorizado o el hallazgo de un dispositivo desconocido conectado a un equipo corporativo.
- **Acuse de recibo:** Todo empleado deberá firmar un acuse de recibo confirmando que ha leído y comprendido esta política antes de que se le conceda cualquier acceso a almacenamiento externo.

7. Conclusión

La implementación de esta política de DLP para dispositivos de almacenamiento externo permite a la organización extender el Principio del Menor Privilegio más allá de las plataformas en la nube, cubriendo uno de los vectores de fuga de datos más críticos y

frecuentemente desatendidos. La combinación de controles técnicos (bloqueo por defecto, cifrado, DLP e inspección de contenido), procesos claros de aprobación y auditoría, y una cultura de concientización constante, reduce significativamente el riesgo de pérdida o exposición no autorizada de información sensible.